

GAP REPORT (Corrected) — apps/admin_web vs Master Blueprint (zip2.0 → zip2.8)

Summary

This report corrects the earlier gap assessment. Contrary to the existing docs/admin_web_analysis.{html,pdf} verdict, the admin UI routes **do exist** in the current repository state.

What is present in apps/admin_web (confirmed)

Routes (admin group)

All six blueprint admin pages are present under apps/admin_web/app/(admin)/:
- app/(admin)/dashboard/page.tsx → /dashboard - app/(admin)/finance/page.tsx → /finance - app/(admin)/finance/payouts/page.tsx → /finance/payouts
- app/(admin)/advertiser/page.tsx → /advertiser - app/(admin)/polls/page.tsx → /polls - app/(admin)/moderation/page.tsx → /moderation

Shared admin layout (sidebar)

- app/(admin)/layout.tsx wraps pages with components/admin/AdminShell.
- components/admin/AdminShell.tsx renders the sidebar nav.

Auth/RBAC utilities

- lib/auth.ts exists and implements getCurrentAdmin() using a session cookie verified with Firebase Admin auth.verifySessionCookie().

Repositories

- lib/repositories/adminMetrics.ts provides dashboard/finance/advertiser/poll metrics functions.
- lib/repositories/moderationRepository.ts provides moderation report queue read + transactional resolution.

Remaining gaps / risks (based on code evidence)

These are the actionable gaps still not fully evidenced/confirmed by the file inspection performed.

Gap A — Admin auth guard enforcement is not proven at the route/layout layer

- AdminShell is a UI-only wrapper (sidebar + layout). It does **not** call getCurrentAdmin().
- app/(admin)/layout.tsx also does not call getCurrentAdmin().

- `app/(public)/login/page.tsx` is only a UI stub; the secure session cookie creation / persistence logic was not inspected.

Risk: admin pages could render without RBAC gating unless enforced elsewhere (middleware, route handlers, or API-layer guards).

Gap B — Metrics semantics may not match blueprint KPI definitions

- The metrics repositories mostly appear to implement Firestore **count-based** KPIs (e.g., counts of collections / filtered where-counts).

Risk: blueprint KPI expectations (e.g., revenue-per-time-window, vote velocity, fraud holds breakdowns, pending payout amounts) may not be satisfied by counts.

Gap C — Firestore security-rule alignment not validated here

- While `firestore/rules/firestore.rules` exists, we did not verify that the rules grant admin-read permissions for the exact collections queried by the repositories.

Risk: CI/security gates may fail even if UI routes build.

Scorecard (corrected)

- Routes implemented: **6/6** (present)
- Shared layout/sidebar: **Yes**
- Auth/RBAC: **Utilities exist; enforcement not evidenced**
- KPI correctness: **Unverified; likely incomplete**
- Firestore rules alignment: **Unverified**

Recommended verification checklist (to close the remaining gaps)

1. Confirm where `getCurrentAdmin()` is invoked for (admin) routes.
2. Verify login flow creates `ADMIN_SESSION_COOKIE_NAME` with a Firebase session cookie.
3. Validate KPI computations in `adminMetrics.ts` against blueprint KPI definitions.
4. Validate Firestore rules grant admin role reads for:
 - `walletLedger`, `walletBalances`, `walletPayouts`, `walletReconciliation`
 - `creatorEarnings`, `riskReviews`, `financeAuditLogs`
 - `moderationReports`, `moderationAuditLogs`
 - `ads/polls` collections used by repositories

PDF artifact

The repository already contains `docs/admin_web_analysis.pdf`, but it was generated from an outdated assumption (that admin routes were missing). This corrected report is provided as source-of-truth markdown.